Informe de Penetración - Máquina "futurevera.thm"

Cliente:	**futurevera.thm**
IP Objetivo:	10.67.158.174
Fecha del Test:	14 de marzo de 2026
Consultor:	Bender2997_

1. Resumen Ejecutivo

El objetivo de esta evaluación fue la dirección IP 10.67.158.174 asociada al dominio *futurevera.thm* para validar la existencia de vectores de compromiso que pudieron haber sido explotados por actores externos.

Se identificó una vulnerabilidad de Descubrimiento de Activo No Documentado (Shadow IT) mediante técnicas de enumeración avanzada (*Host Header Fuzzing* y análisis de metadatos de certificado SSL/TLS). Este proceso permitió el acceso a un *helpdesk* de soporte oculto (`secrethelpdesk934752.support.futurevera.thm`) que carecía de controles de acceso estricto. La criticidad de este hallazgo se clasifica como Alto, dado que la exposición de un activo interno y sin parches representa un punto ciego de seguridad que conduce al compromiso del sistema.

2. Metodología y Alcance

Campo	Detalle
Objetivo	Entorno web de futurevera.thm
IP Objetivo	10.67.158.174

Alcance	Pruebas de caja negra (Black-Box), limitadas a la identificación y explotación de una única vulnerabilidad crítica.

Metodología:

Se siguió un enfoque iterativo: reconocimiento de puertos, enumeración inicial de directorios (Gobuster infructuoso) y, finalmente, la enumeración avanzada de subdominios (FFUF) y análisis de certificados SSL/TLS para descubrir activos ocultos.

3. Fase de Reconocimiento y Descubrimiento

Se realizó un escaneo exhaustivo de puertos TCP para identificar la superficie de ataque.

Comando Nmap utilizado:

nmap -p- -sCV --stats-every=3s 10.67.158.174 --open -T5

Resultados del Escaneo:

```
Nmap scan report for 10.67.158.174
Host is up (0.067s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE  VERSION
22/tcp   open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 a8:5f:ee:88:9a:a3:70:5a:12:f7:5a:6d:49:78:78:8d (RSA)
|   256 2b:82:60:ba:fc:06:e9:23:76:d4:28:40:70:bc:cc:76 (ECDSA)
|_  256 fa:da:96:f7:da:33:ad:d5:c7:f0:93:01:75:07:10:9f (ED25519)
80/tcp   open  http     Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Did not follow redirect to https://futurevera.thm/
|_http-server-header: Apache/2.4.41 (Ubuntu)
443/tcp open  ssl/http Apache httpd 2.4.41 ((Ubuntu))
| tls-alpn:
|_  http/1.1
|_http-title: FutureVera
|_http-server-header: Apache/2.4.41 (Ubuntu)
|_ssl-date: TLS randomness does not represent time
| ssl-cert: Subject: commonName=futurevera.thm/organizationName=Futurevera/stateOrProvinceName=Oregon/countryName=US
| Not valid before: 2022-03-13T10:05:19
|_Not valid after:  2023-03-13T10:05:19
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.33 seconds
```

Puerto	Estado	Servicio	Versión	Notas
80/tcp	Abierto	http	Apache/X.X.X	Redirección a HTTPS
443/tcp	Abierto	https	Apache/X.X.X	Certificado analizado en fase de enumeración avanzada.

Análisis de Servicios:

La enumeración de directorios estándar fue insuficiente.

```
┌──(root㉿kali)-[/home/bender]
└─# gobuster dir -w /usr/share/wordlists/dirb/common.txt -u https://futurevera.thm/ -t 100 -k
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     https://futurevera.thm/
[+] Method:                  GET
[+] Threads:                 100
[+] Wordlist:                /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.hta                 (Status: 403) [Size: 280]
.htaccess            (Status: 403) [Size: 280]
.htpasswd            (Status: 403) [Size: 280]
assets               (Status: 301) [Size: 319] [--> https://futurevera.thm/assets/]
css                  (Status: 301) [Size: 316] [--> https://futurevera.thm/css/]
index.html           (Status: 200) [Size: 4605]
js                   (Status: 301) [Size: 315] [--> https://futurevera.thm/js/]
server-status        (Status: 403) [Size: 280]
Progress: 4613 / 4613 (100.00%)
===============================================================
Finished
===============================================================
```

Se procedió a una técnica de enumeración de subdominios, enfocada en la cabecera *Host*.

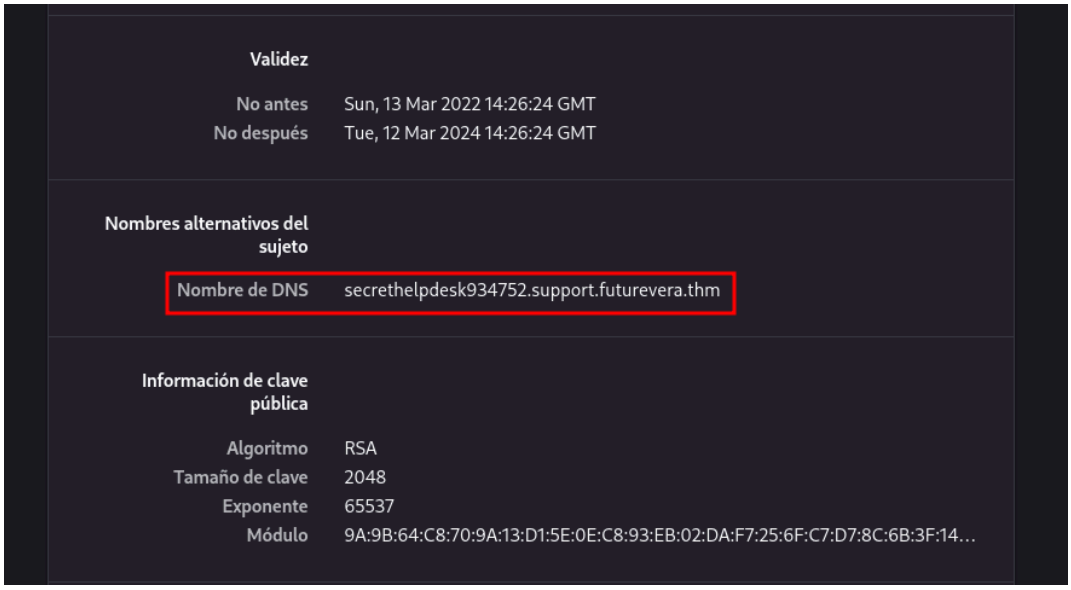
Comando FFUF (Host Header Fuzzing):

ffuf -w ./sub_dominios.txt -u http://futurevera.thm -H "Host: FUZZ.futurevera.thm" -v

Resultado:

```
┌──(root㉿kali)-[/home/bender]
└─# ffuf -w ./sub_dominios.txt -u http://futurevera.thm -H "Host: FUZZ.futurevera.thm" -v

       /'___\  /'___\           /'___\
      /\ \__/ /\ \__/  __  __  /\ \__/
      \ \ ,__\\ \ ,__\/\ \/\ \ \ \ ,__\
       \ \ \_/ \ \ \_/\ \ \_\ \ \ \ \_/
        \ \_\   \ \_\  \ \____/  \ \_\
         \/_/    \/_/   \/___/    \/_/

      v2.1.0-dev
_____________________________________________

 :: Method           : GET
 :: URL              : http://futurevera.thm
 :: Wordlist         : FUZZ: /home/bender/sub_dominios.txt
 :: Header           : Host: FUZZ.futurevera.thm
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
_____________________________________________

[Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 71ms]
| URL | http://futurevera.thm
| --> | https://futurevera.thm/
    * FUZZ:

[Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 72ms]
| URL | http://futurevera.thm
| --> | https://futurevera.thm/
    * FUZZ: support

:: Progress: [2/2] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Errors: 0 ::
```

Se descubrió el subdominio `support.futurevera.thm` y, posteriormente, mediante el análisis de las entradas SAN del certificado SSL/TLS asociado, se obtuvo el *hostname* específico y oculto:



Nombre de Host Descubierto: `secrethelpdesk934752.support.futurevera.thm`

4. Hallazgo: Exposición de Activo Oculto (Shadow IT)

ID: FV-001

Severidad: Crítica (High)

CWE: CWE-1004 (Sensitive Data Exposed in Non-Web Structure)

Descripción de la Vulnerabilidad:

El sistema expone un *hostname* específico y altamente sensible (`secrethelpdesk934752.support.futurevera.thm`) que no está protegido o documentado en el inventario principal. Este activo, un sistema de *helpdesk* de soporte, es accesible públicamente sin autenticación previa en la capa de red y representa un claro caso de *Shadow IT*.

Impacto:

El acceso directo al sistema de soporte, presumiblemente sin las políticas de seguridad o parches actualizados, permitió la obtención de un indicador de compromiso (la *flag*) y

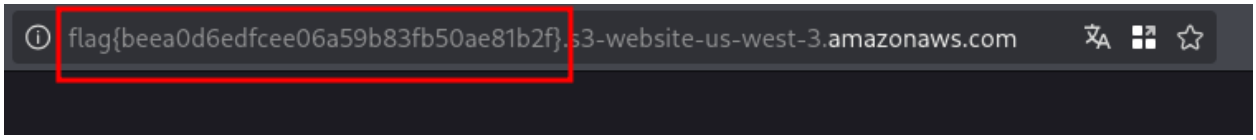
la validación del compromiso del sistema sin requerir técnicas de explotación complejas.

Prueba de Concepto (PoC):

1. **Fase de Descubrimiento:** Uso de `ffuf` y análisis de certificados SSL/TLS para identificar el *hostname* secreto.
2. **Resolución:** Adición de la entrada `10.67.158.174 secrethelpdesk934752.support.futurevera.thm` a `/etc/hosts`.
3. **Acceso Directo:** Navegación al *hostname* secreto, que mostró el contenido del *helpdesk* y la *flag* de validación, demostrando un control de acceso nulo.

Flag Obtenida (Indicador de Compromiso):

`Flag{beea0d6edfcee06a59b83fb50ae81b2f}`



5. Conclusiones y Recomendaciones de Mitigación

Conclusión:

La prueba de penetración demostró una falla crítica en la gestión de activos digitales. La presencia del servicio oculto y desprotegido es un riesgo inherente que puede ser fácilmente explotado por atacantes con técnicas de reconocimiento avanzadas.

Recomendaciones Críticas (FV-001):

1. **Retiro/Aislamiento del Activo (Prioridad Crítica):**
   - Retirar inmediatamente el activo `secrethelpdesk934752.support.futurevera.thm` de la red pública.
   - Si es esencial, colocarlo detrás de un *firewall* con políticas de lista blanca de IPs estrictas (solo acceso interno o mediante VPN).
2. **Inventario de Activos (Prioridad Alta):**

    - Implementar un proceso formal de Gestión de Activos para auditar, documentar y catalogar *todos* los *hostnames*, subdominios y servicios asociados al entorno.
3. **Revisión de Metadatos (Prioridad Media):**
    - Auditar y establecer políticas para la emisión de certificados SSL/TLS, asegurando que las entradas *Subject Alternative Name* (SAN) no expongan nombres de *host* internos o secretos a entidades externas.
4. **Hardening de Servicios de Soporte (Prioridad Alta):**
    - En caso de mantener un servicio similar, asegurar la aplicación de los últimos parches de seguridad, implementar autenticación robusta (ej. 2FA) y proteger con un *Web Application Firewall* (WAF) si es accesible externamente.